

Threat Model, Mechanisms & Policies

Taller de Seguridad

Ing. Martin Di Paola – Fiuba

Who wants to attack you?

Are you a target?

Threat Model

Threat Model



Who are the
attackers?



Country
Script Kid
Crimminal
Org

Threat Model

Who are the
attackers?



Country
Script Kid
Crimminal
Org

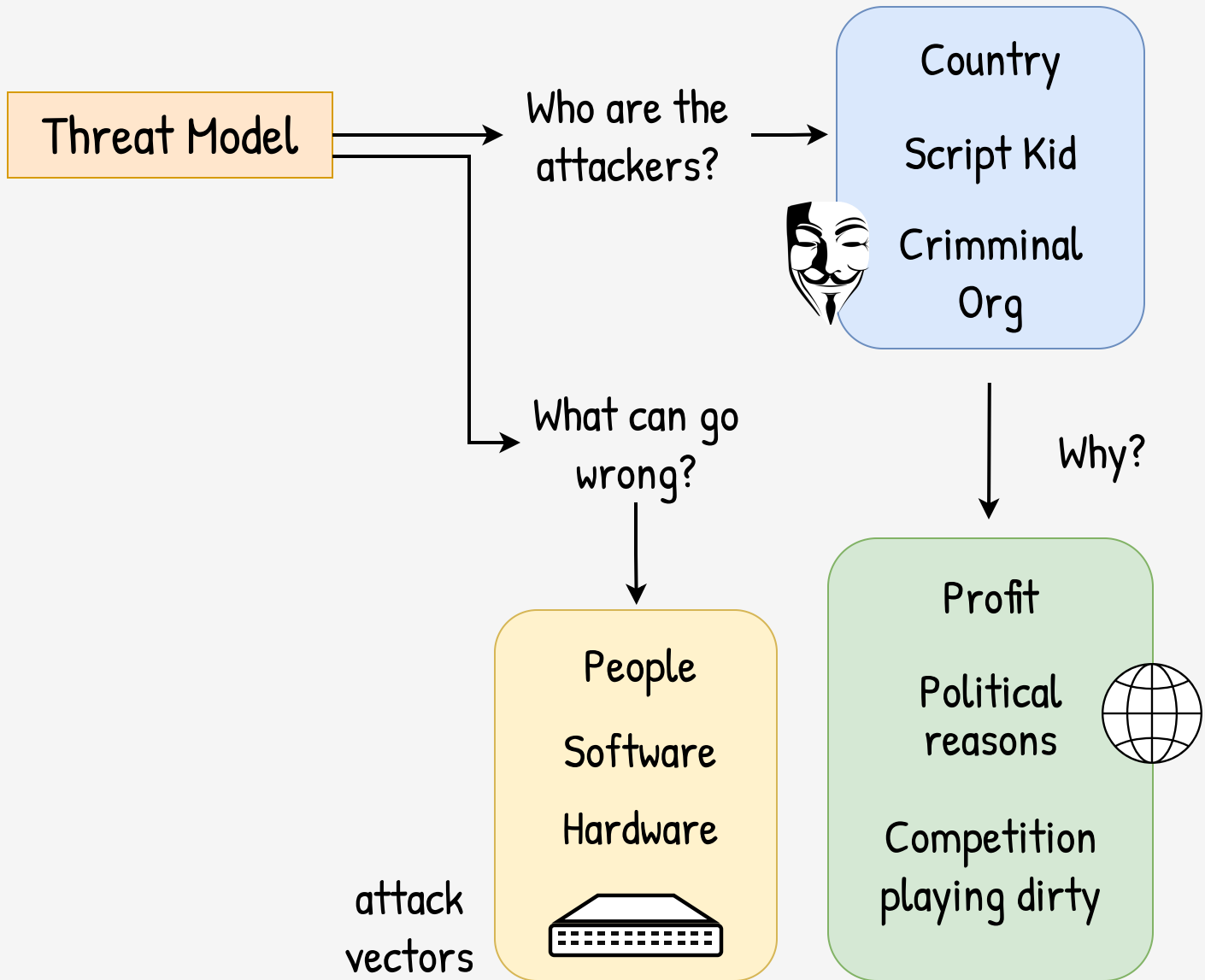
Why?

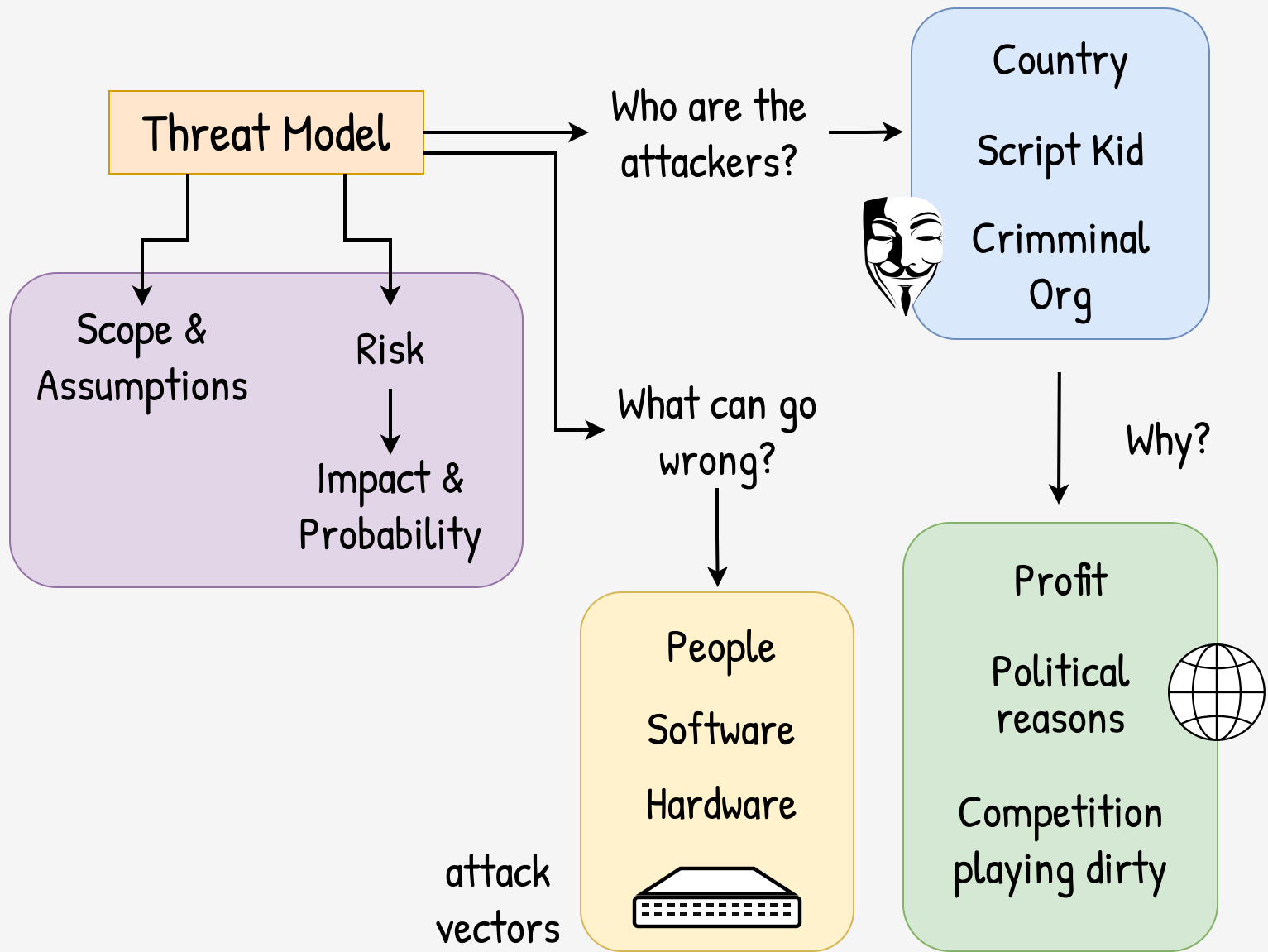
Profit

Political
reasons

Competition
playing dirty







Threat Model



In whom and in what
to Trust?

Zero Trust

Threat Model



Mechanisms



Policies

Threat Model

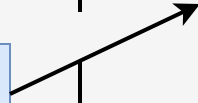


Mechanisms



Policies

What tools
do we have?



Threat Model

Mechanisms

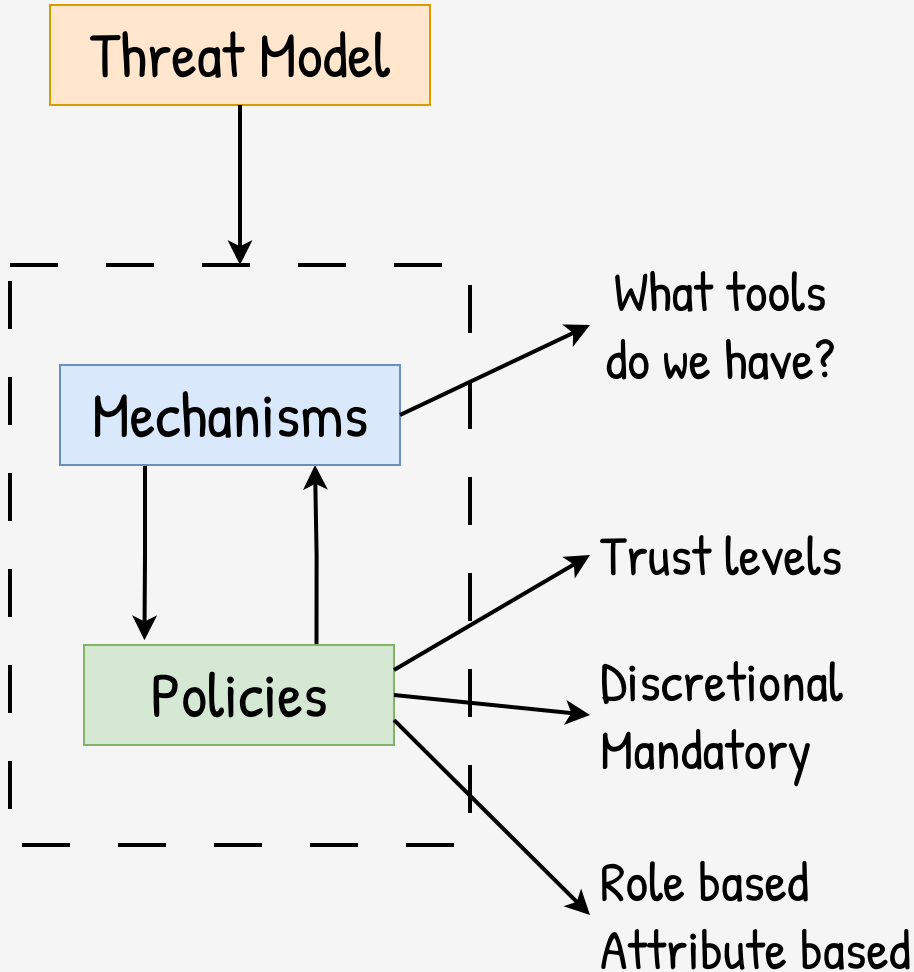
Policies

What tools
do we have?

Trust levels

Discretionary
Mandatory

Role based
Attribute based



Threat Model

Mechanisms

Policies

What tools
do we have?

Trust levels

Discretionary
Mandatory

Role based
Attribute based

Enforce
Monitor
Prevent
Mitigate
Audit
Plan B



Friction
(tradeoff)

Enforce
Monitor
Prevent
Mitigate
Audit
Plan B

Threat Model

Mechanisms

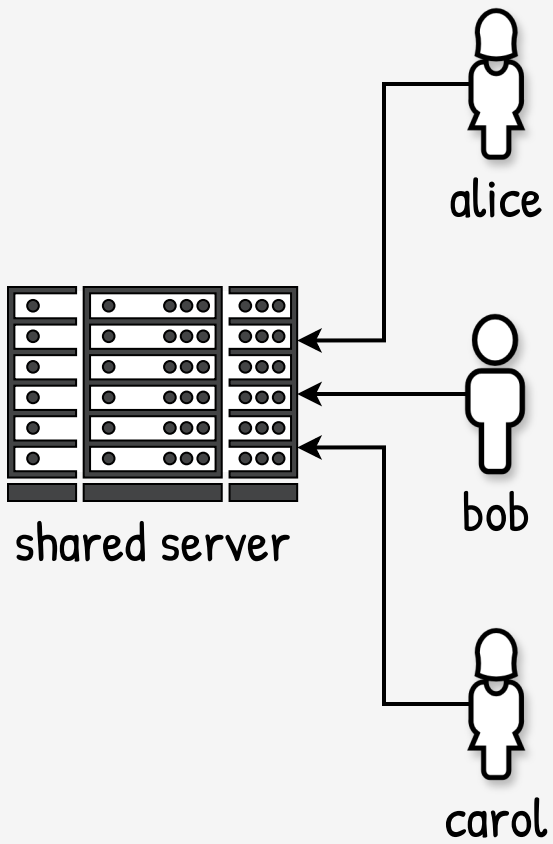
Policies

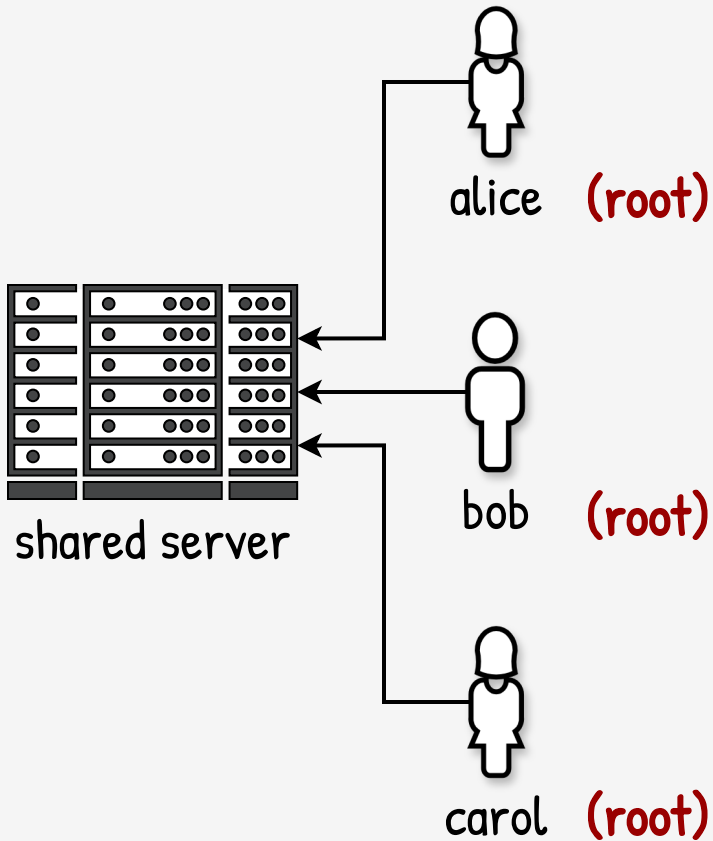
What tools
do we have?

Trust levels

Discretionary
Mandatory

Role based
Attribute based



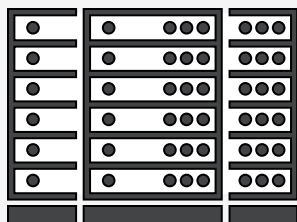


admin:
*"Easy, root for everyone.
I trust you guys."*



hack

alice (root)

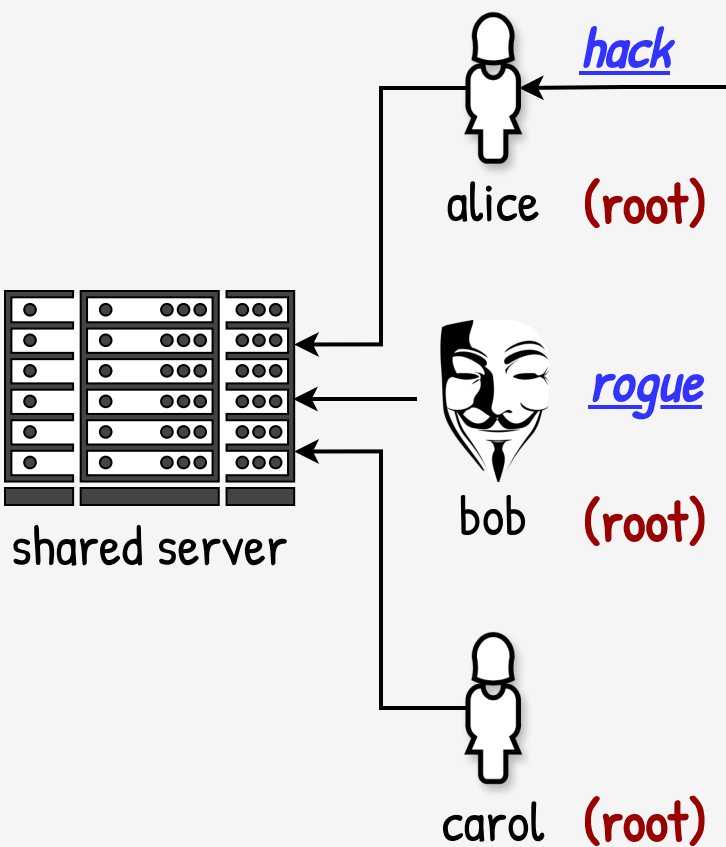


shared server

bob (root)

carol (root)

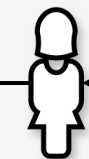
admin:
*"Easy, root for everyone.
I trust you guys."*



admin:
*"Easy, root for everyone.
I trust you guys."*



hack



alice (root)



rogue

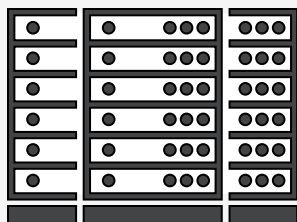
bob (root)



carol (root)

`rm -Rf /`

(shit happens)

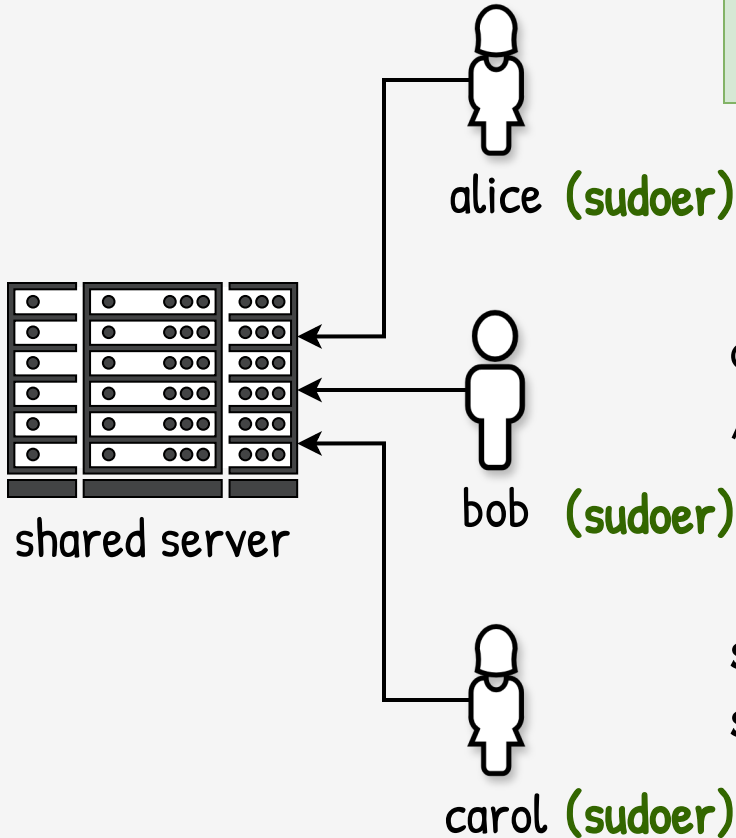


shared server

admin:
*"Easy, root for everyone.
I trust you guys."*

admin:

*"don't trust users; minimum
privileges via sudo"*



sudoers
(conf)

carol ALL=(ALL):
/bin/less /var/log/messages

sudo rm -Rf / ↙ fails
sudo less /var/log/messages ↘ passes

Threat
Model



admin:

*"don't trust users; minimum
privileges via sudo"*

Policy



sudoers
(conf)

carol ALL=(ALL):
/bin/less /var/log/messages

Mechanism



sudo

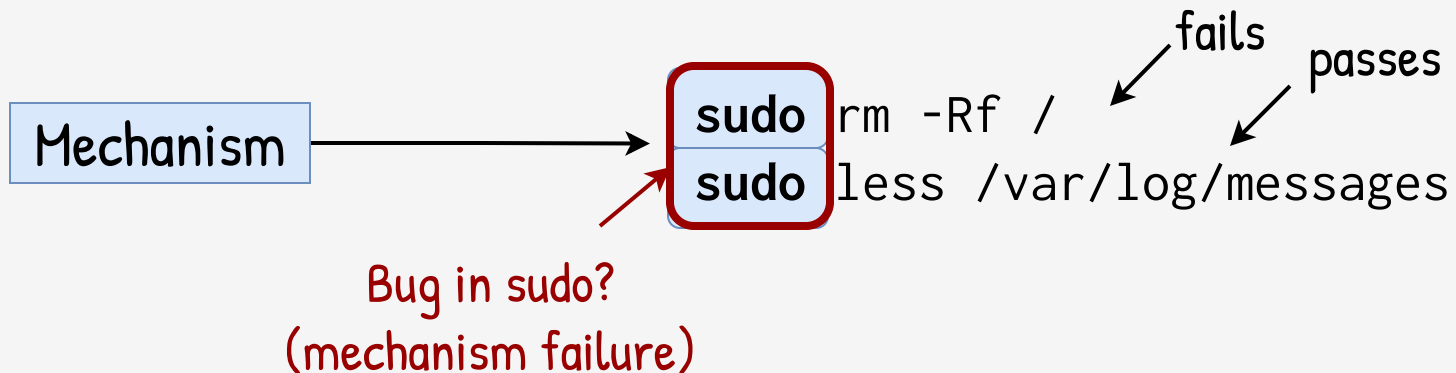
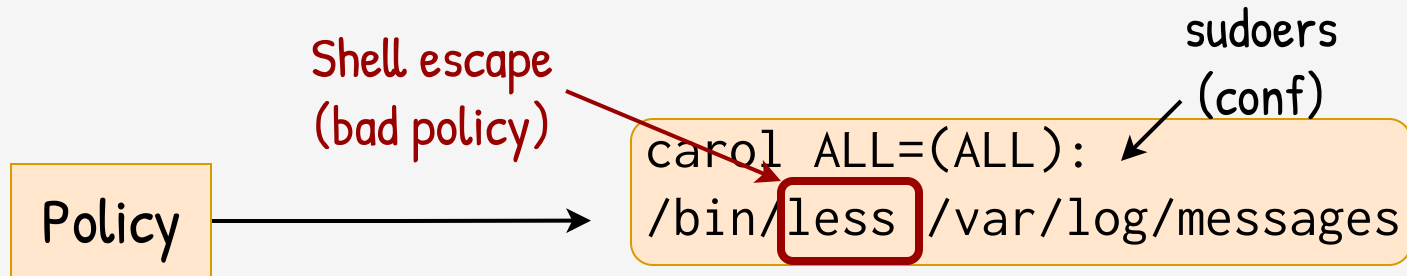
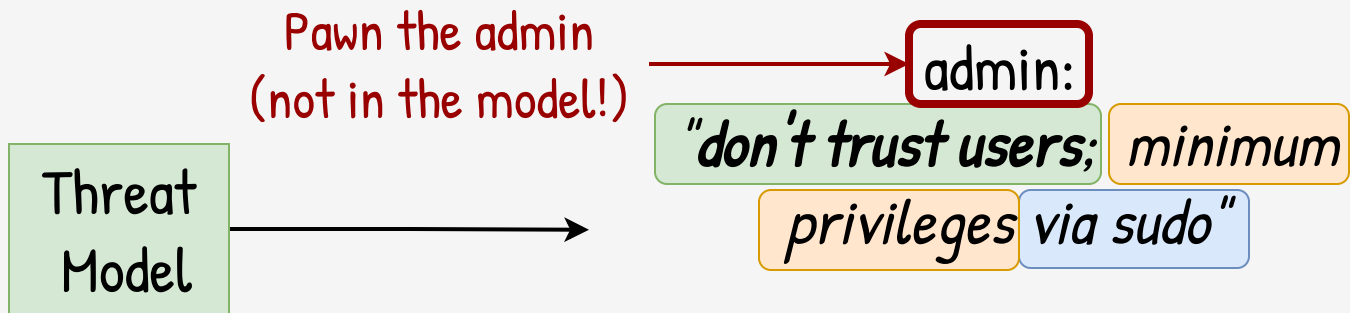
rm -Rf /

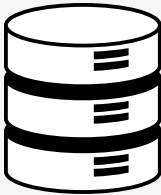
fails

passes

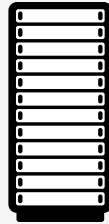
sudo

less /var/log/messages

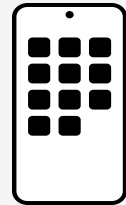




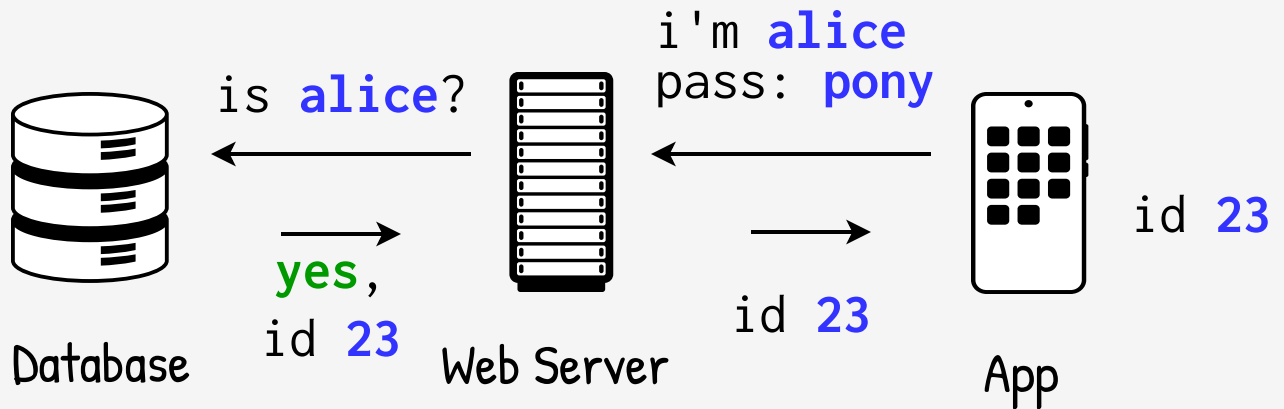
Database



Web Server



App

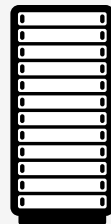



```
select *  
from users  
where id = 23
```

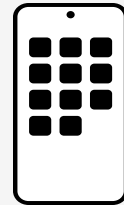
```
select *  
from users  
where id = {id}
```



Database



Web Server



App

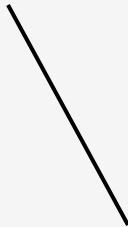
fetch 23

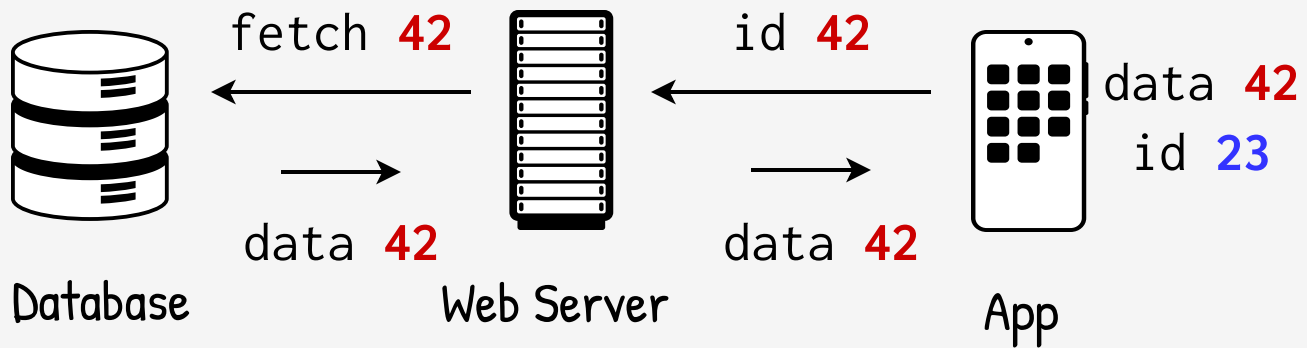
data 23

id 23

data 23

data 23
id 23





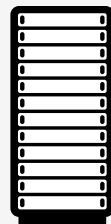
```
select *  
from users  
where id = 0  
or 1=1
```

```
select *  
from users  
where id = {id}
```

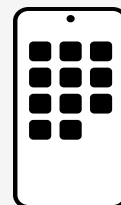
all users' data
belong to the
attacker now



Database



Web Server



App

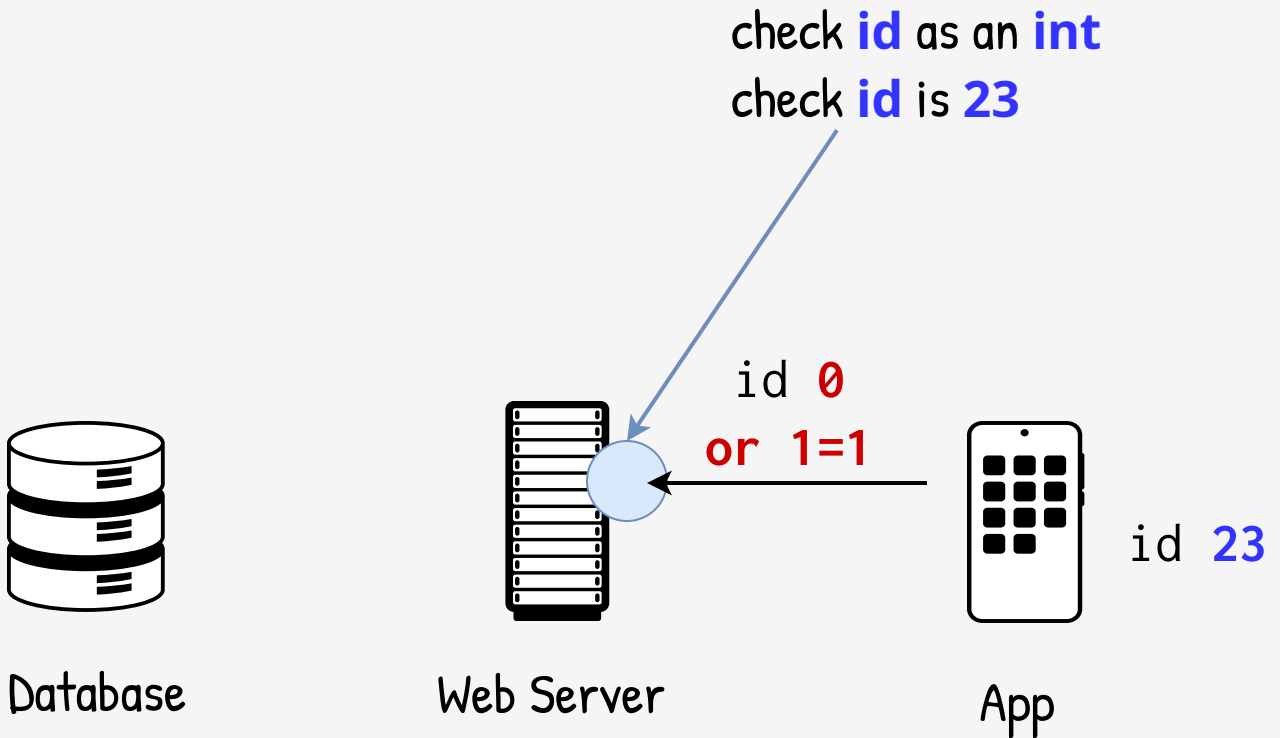
fetch 0
or 1=1

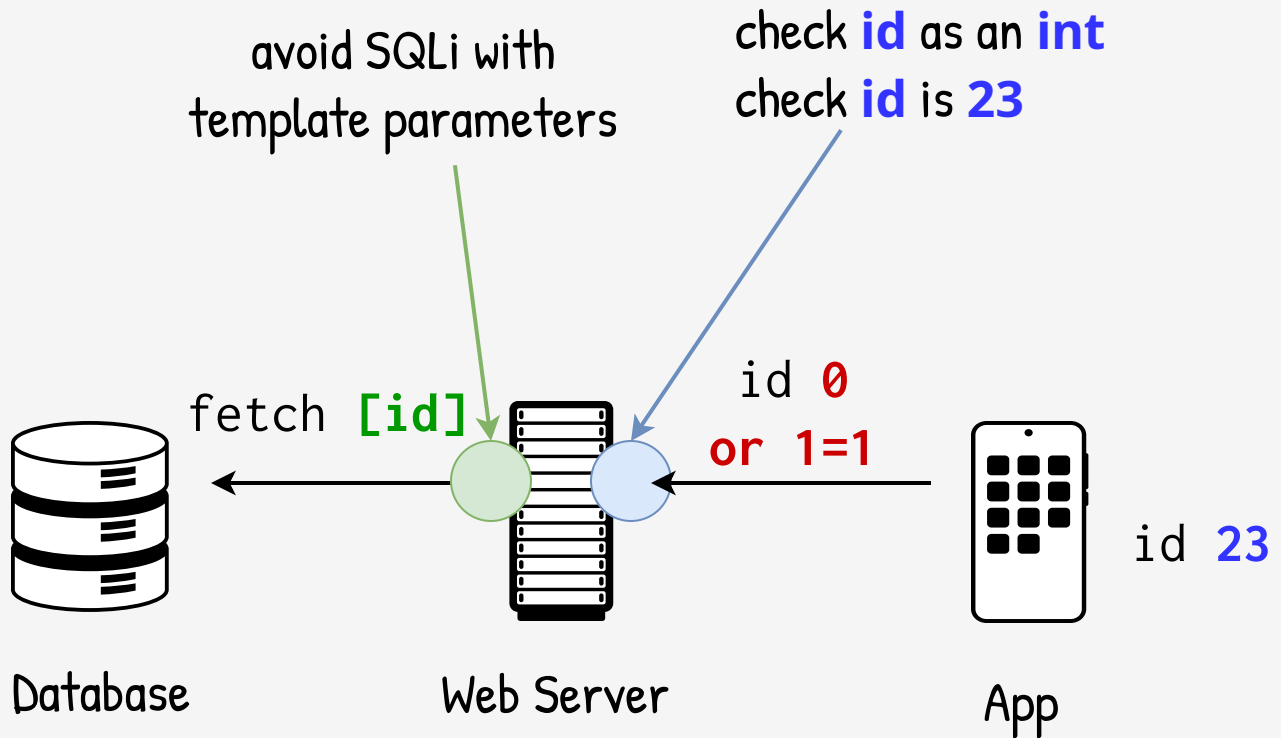
data *

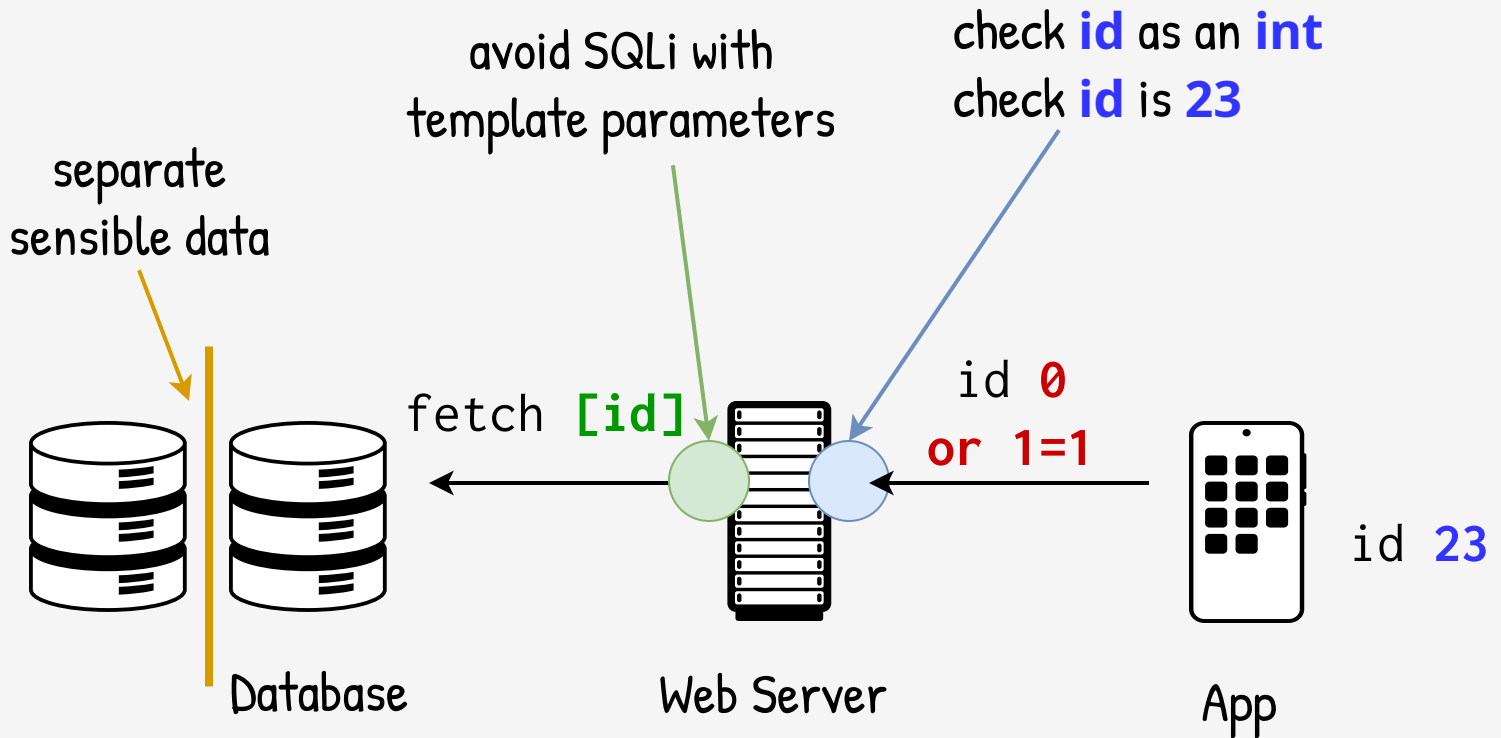
id 0
or 1=1

data *

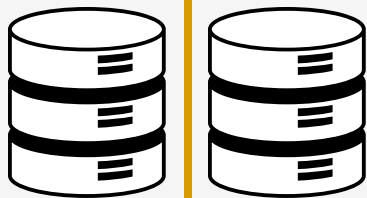
data *
id 23



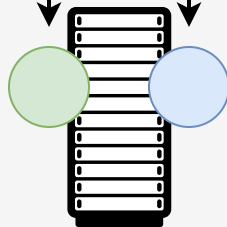




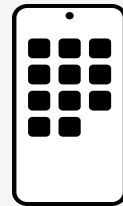
Interfaces



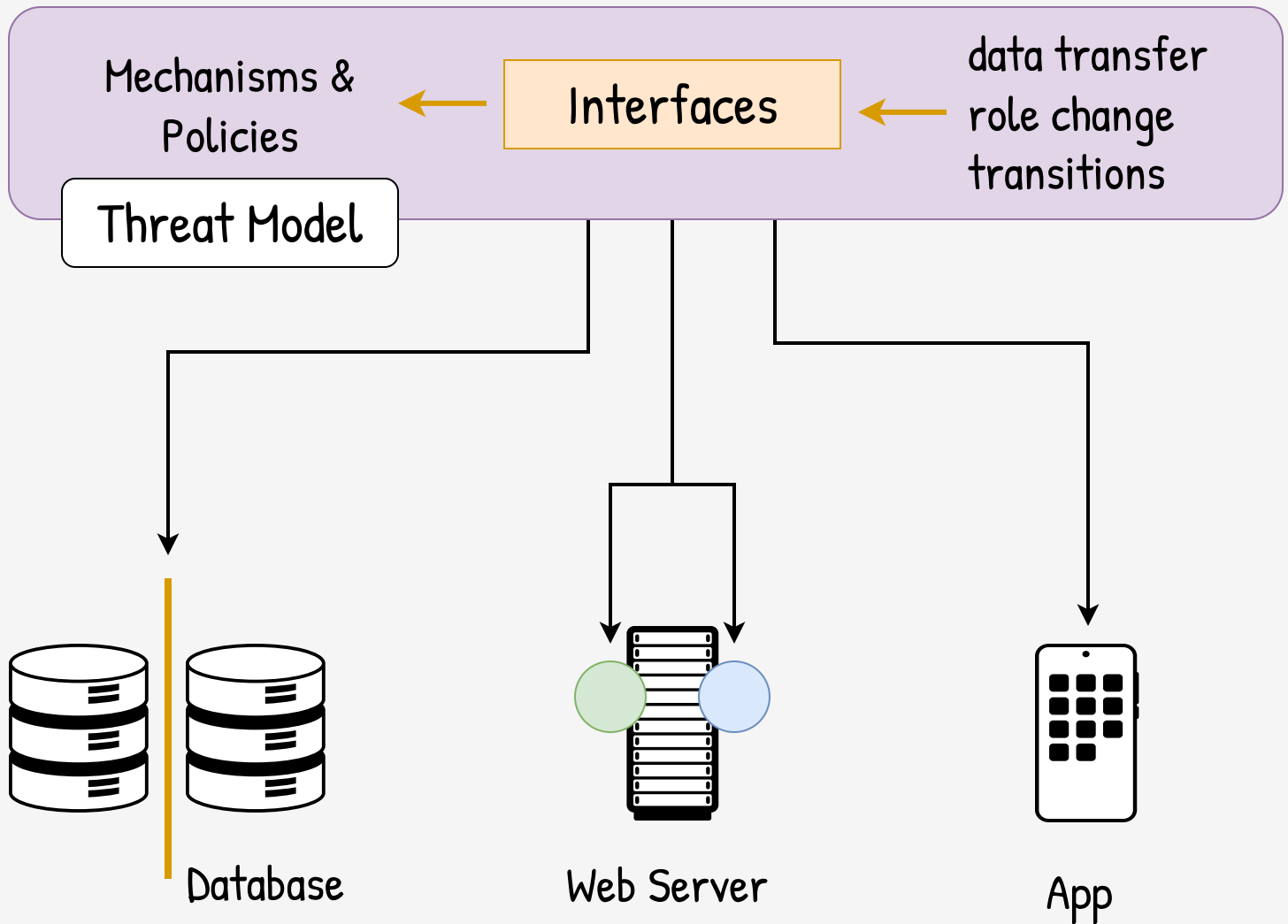
Database



Web Server



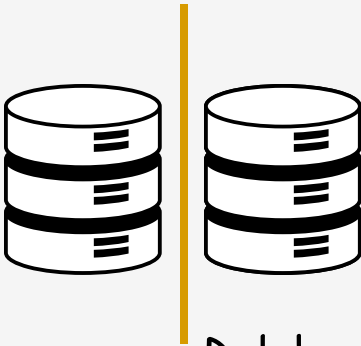
App



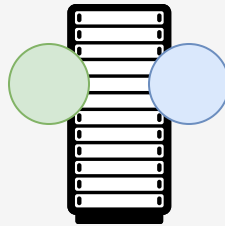
Zero Trust



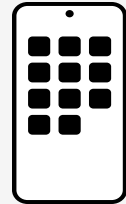
Sec in Depth



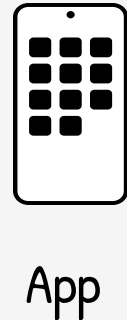
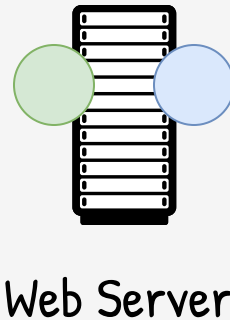
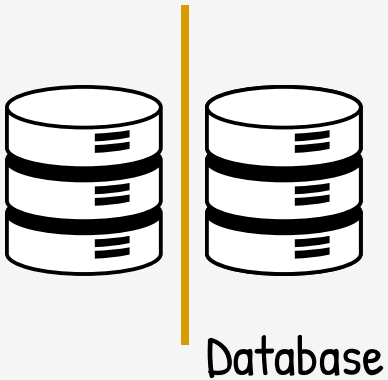
Database

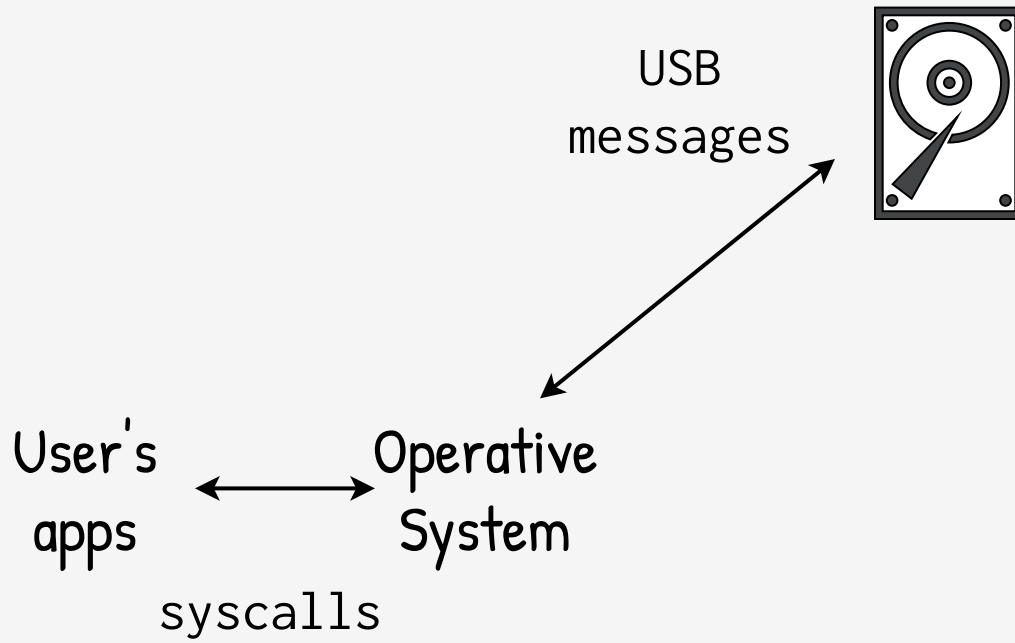


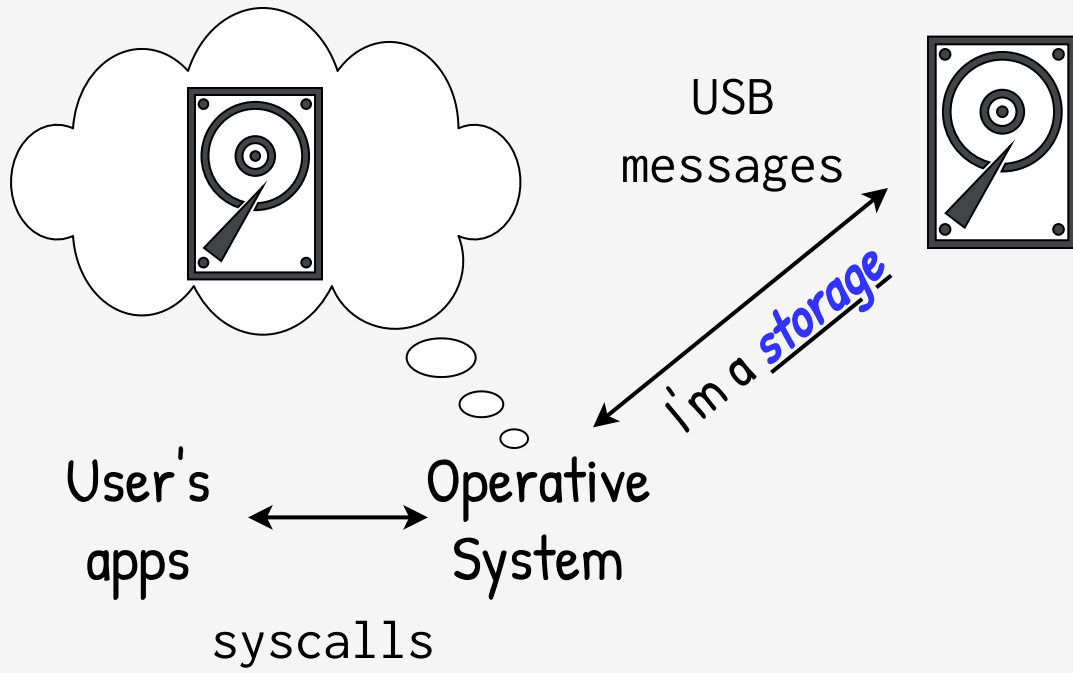
Web Server

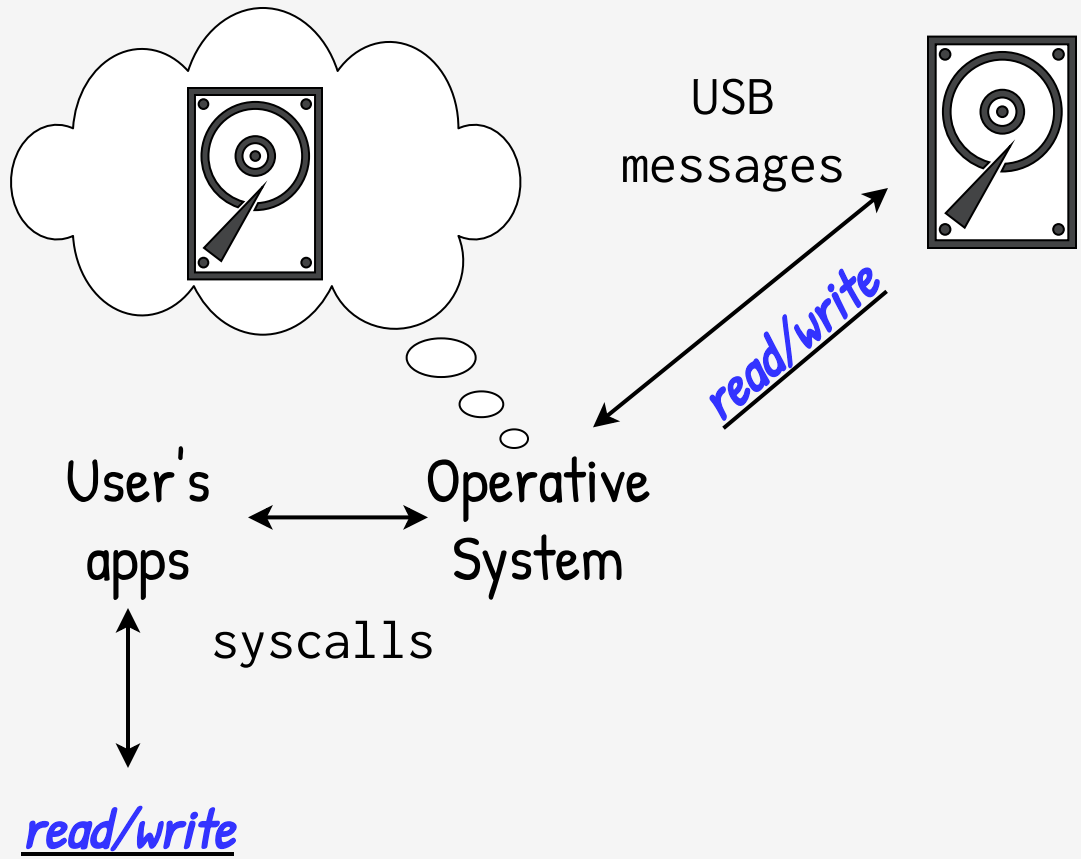


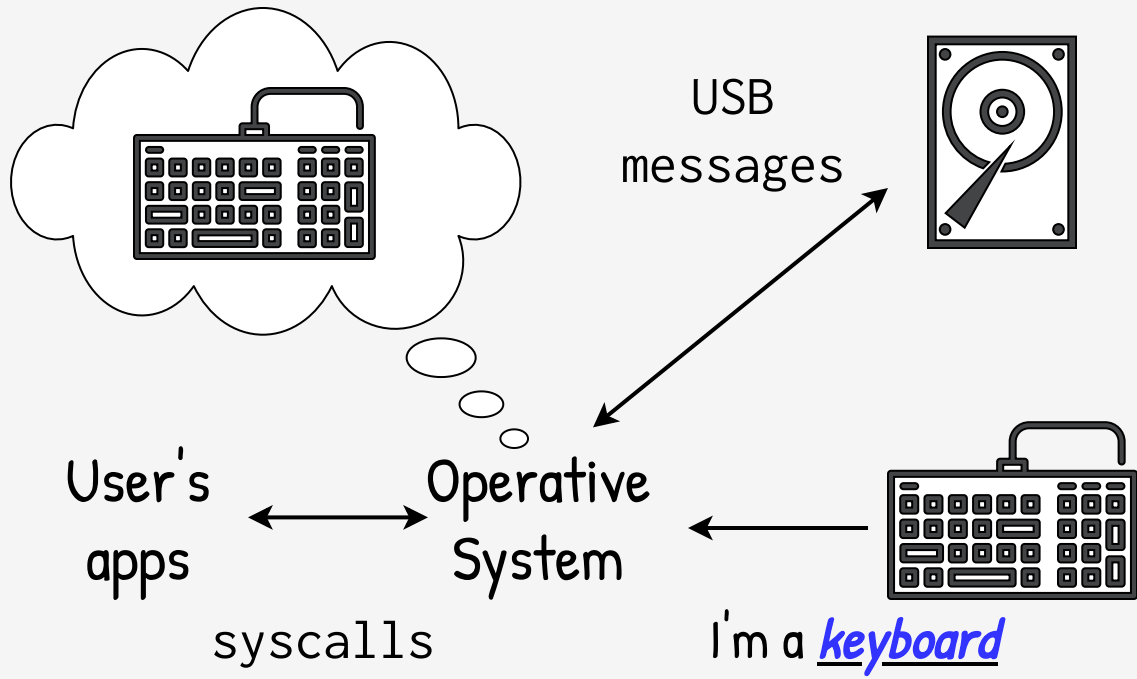
App

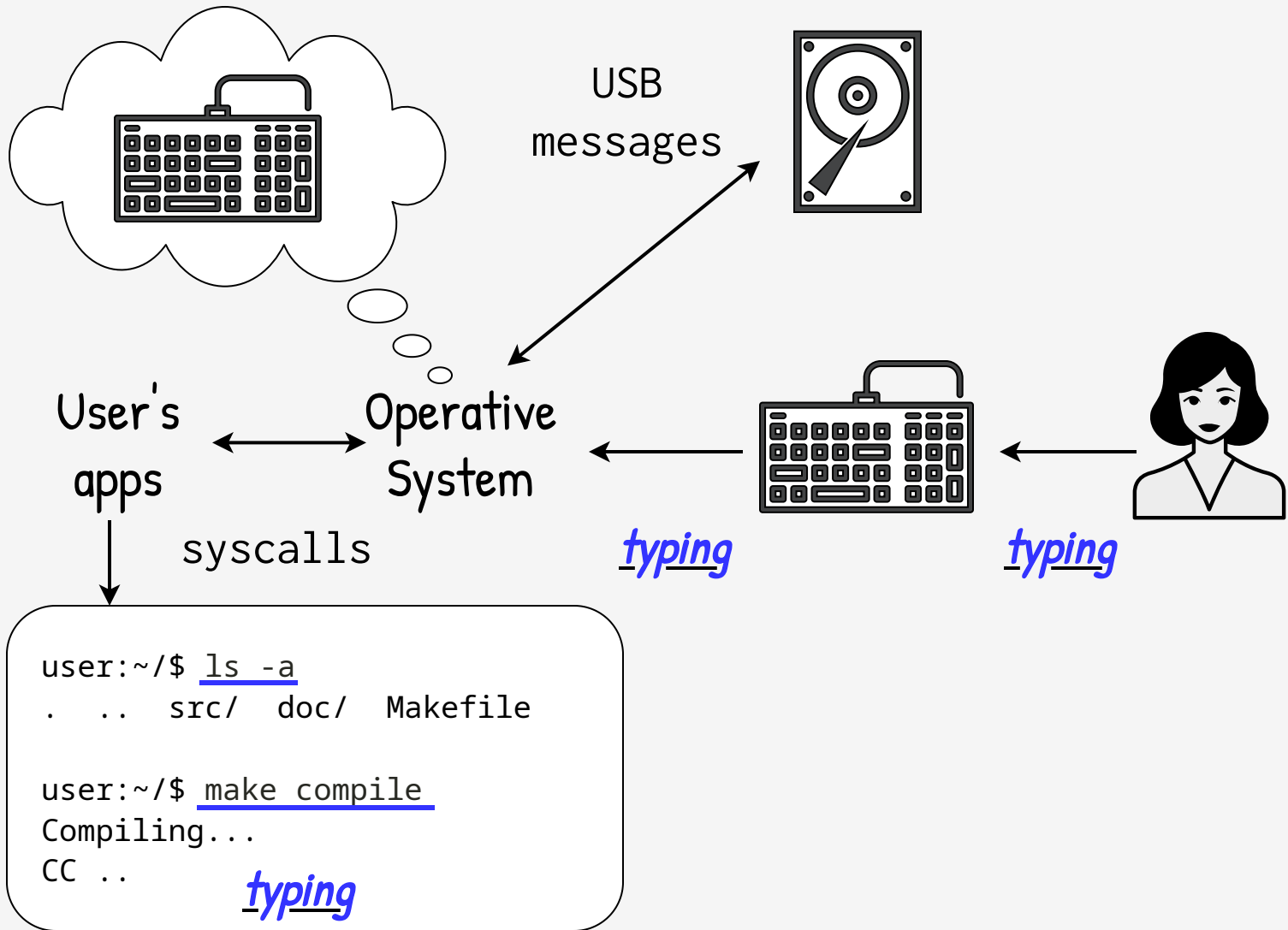


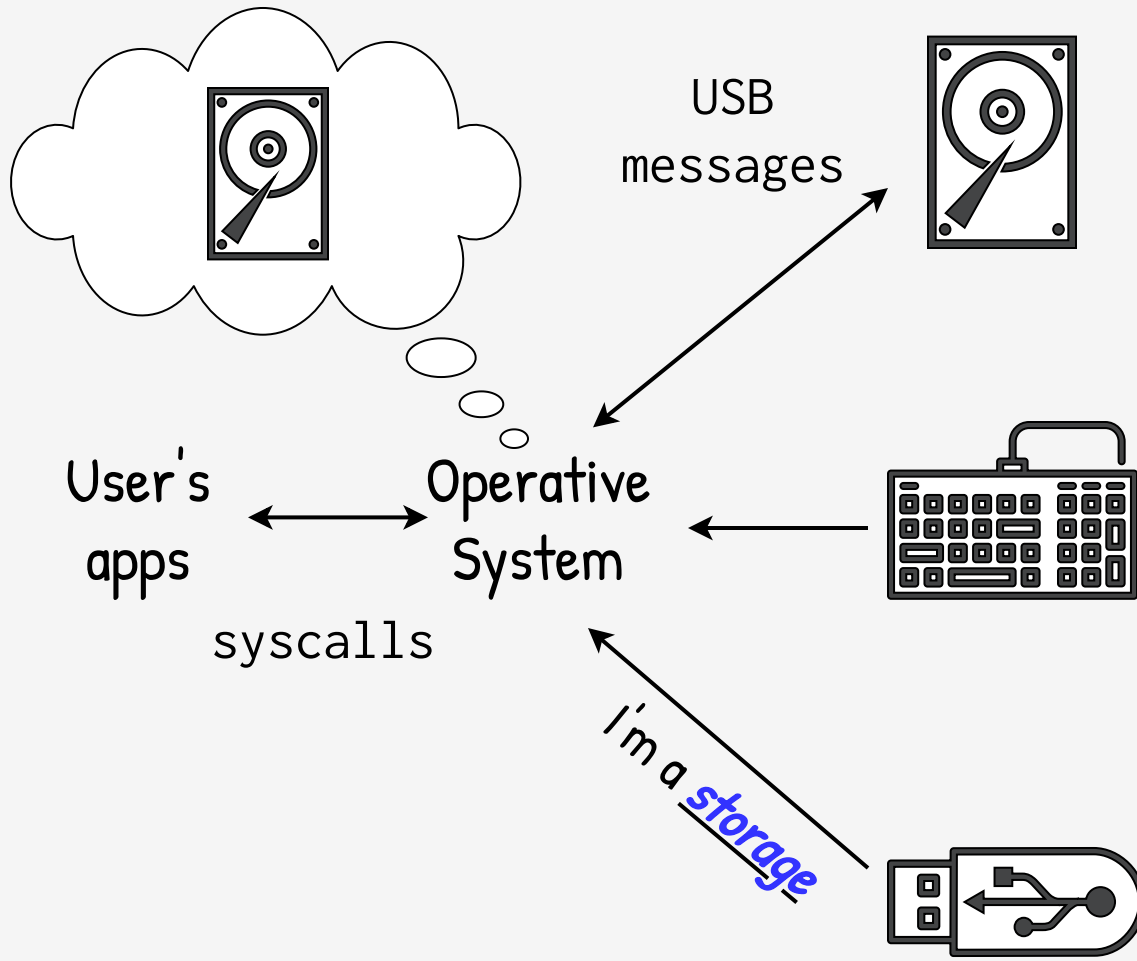


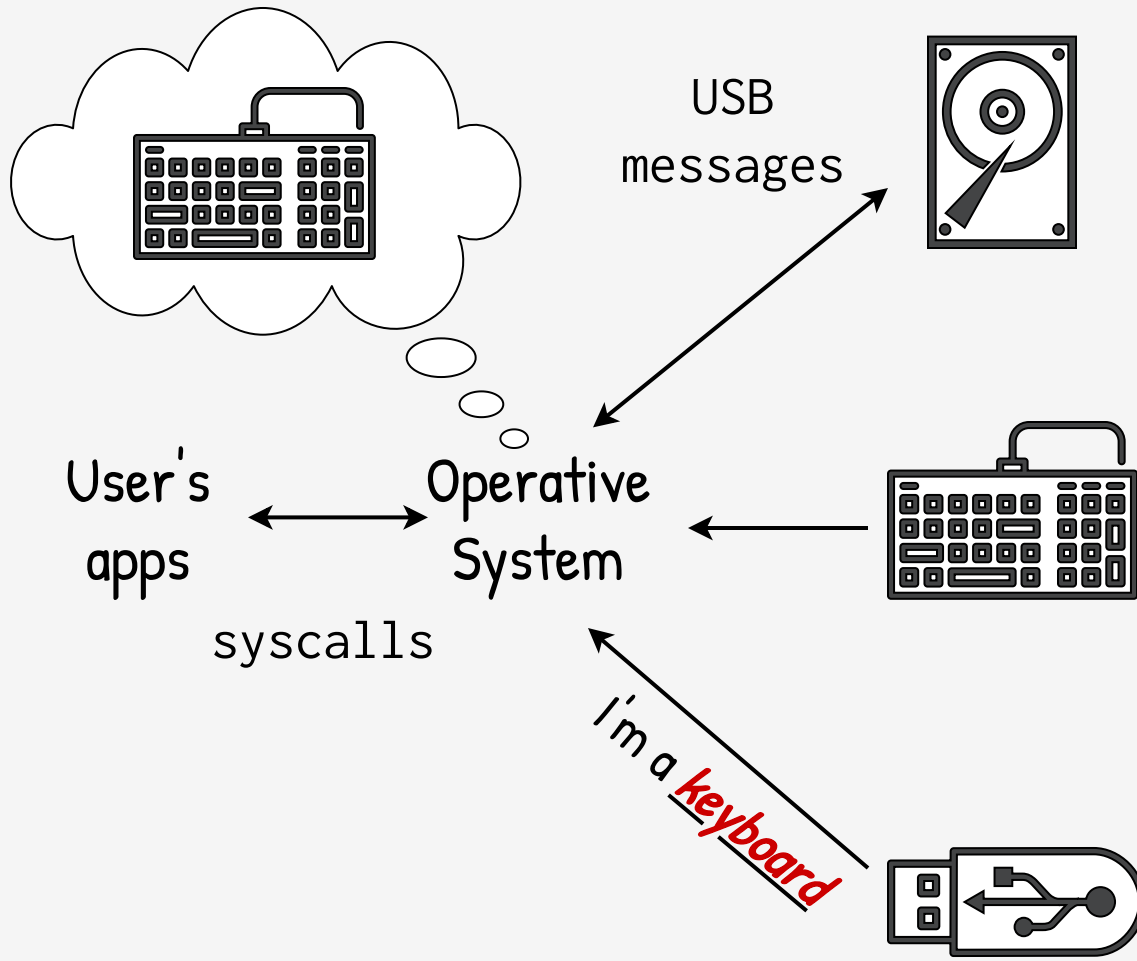


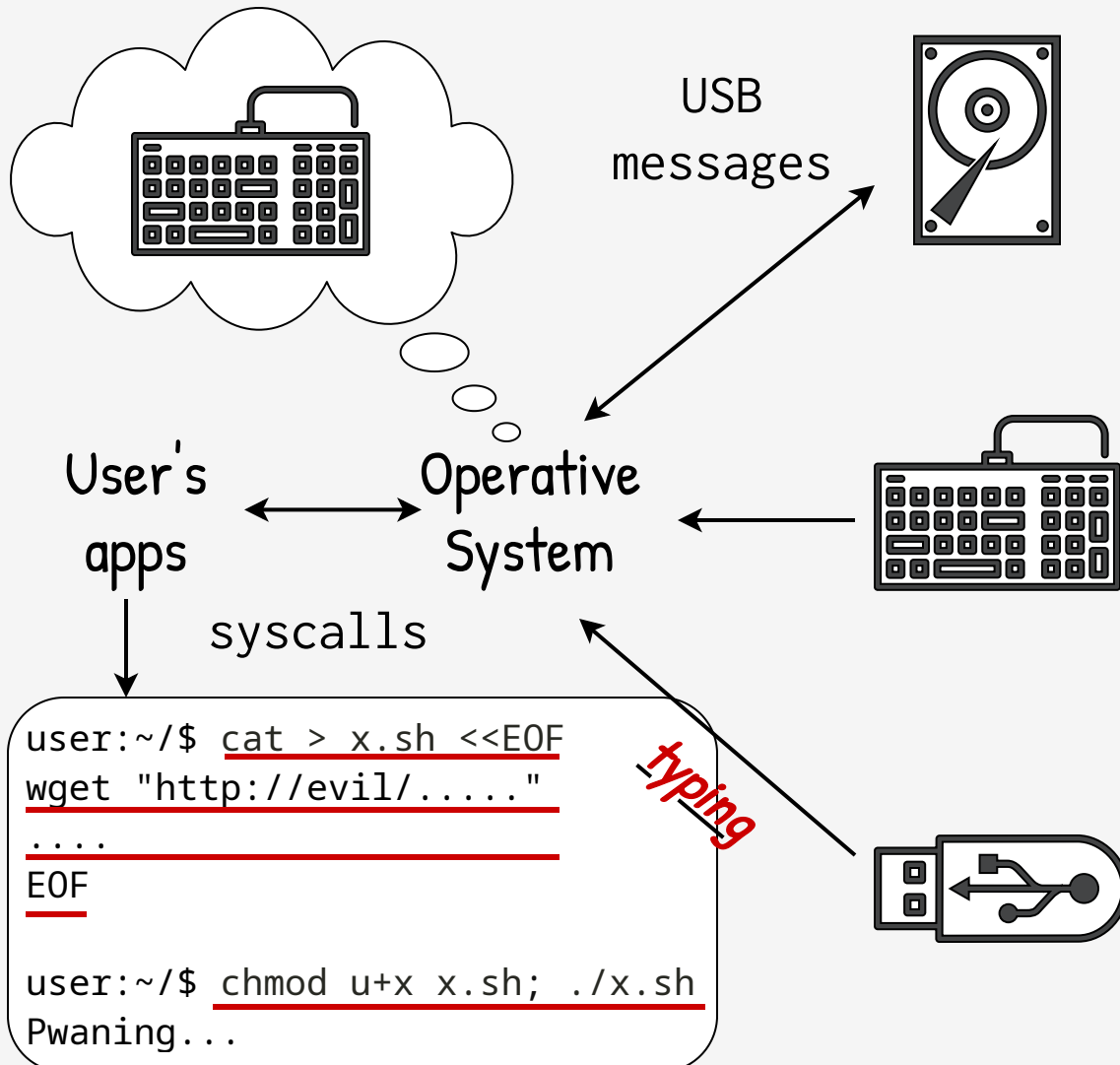


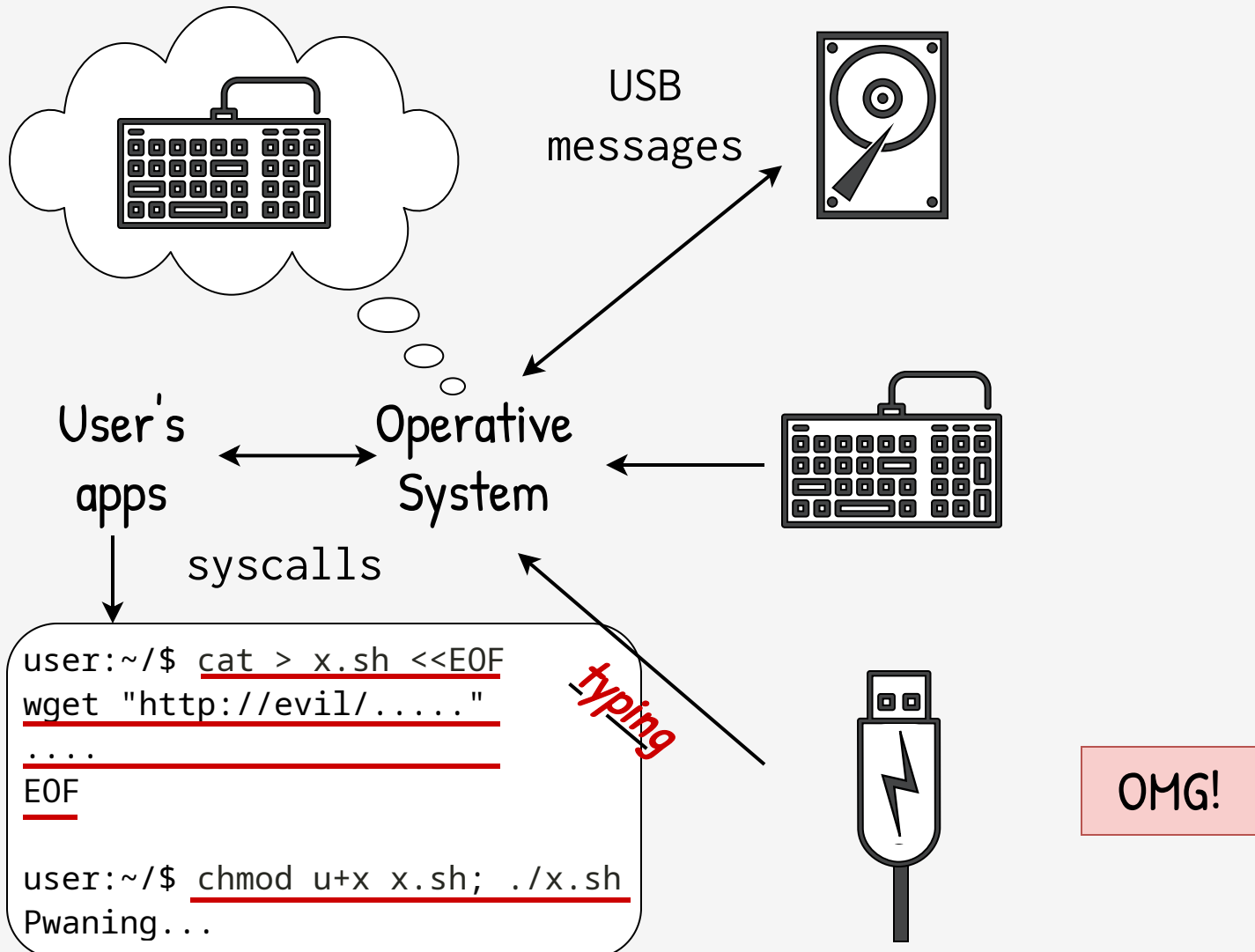












What can go wrong?

Zero Trust